



# 密码协议

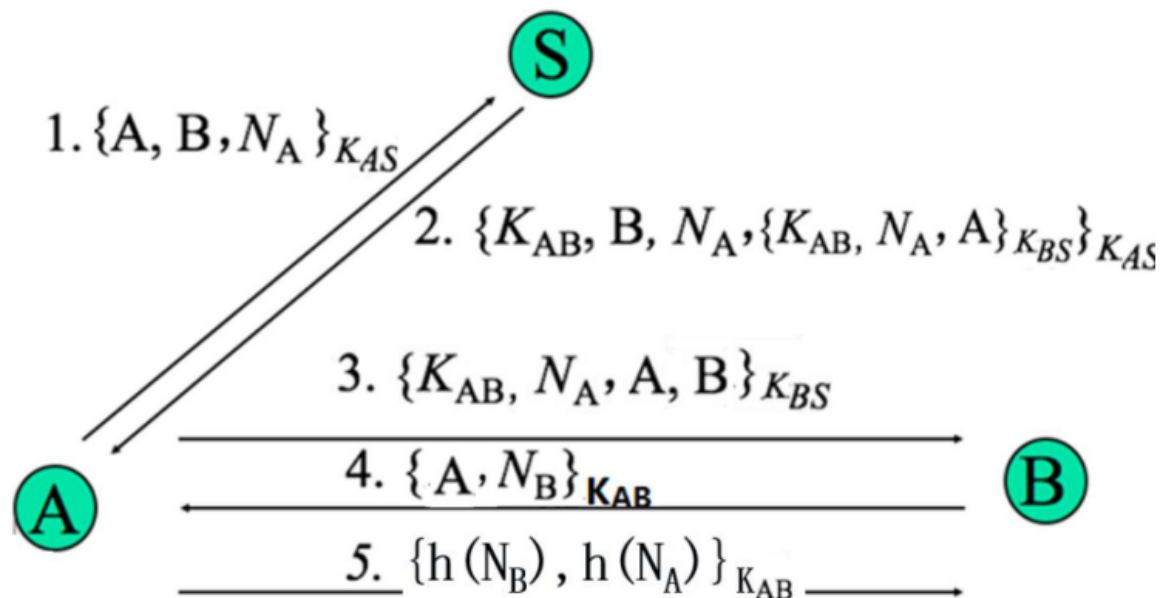
第一次作业讲解

2026年4月16日

1. Diffie-Hellman 协议存在什么协议漏洞？违反了安全协议的哪个性质，该性质一般通过什么实现？应如何改进协议。
2. HMQV 协议中使用参数  $d = H(X, \text{"Bob"})$  和  $e = H(Y, \text{"Alice"})$ ，将意定通信方的身份与密钥派生进行绑定，这样处理的目的是什么？如果改为  $d = H(X)$  和  $e = H(Y)$ ，是否存在安全缺陷？
3. Needham-Schroeder 协议使用什么机制保障消息的新鲜性？试找出 NS\_v6 协议存在的安全缺陷。

### Needham-Schroeder对称密钥认证协议\_v6

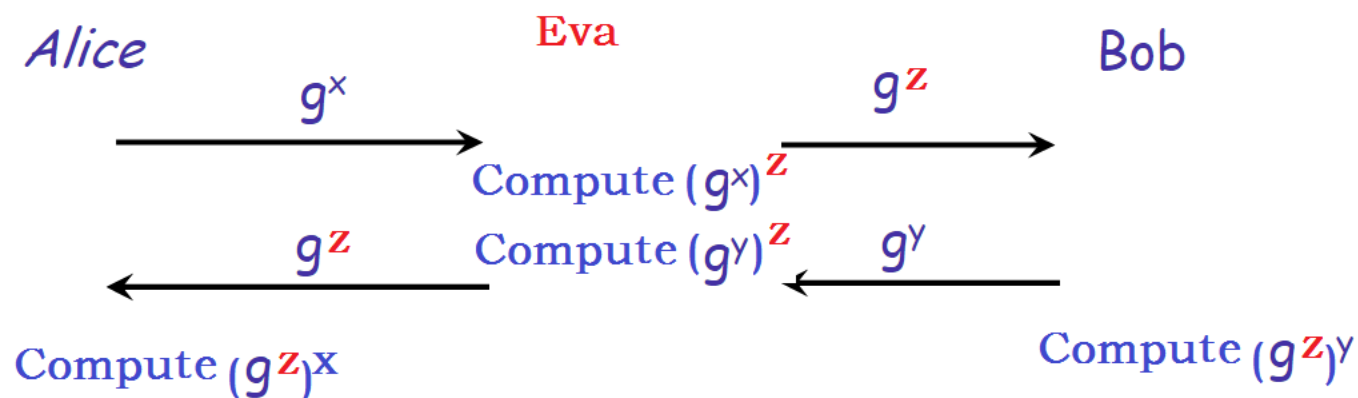
□改进策略：令消息5为  $\{h(N_B), h(N_A)\}_{K_{AB}}$



# 对Diffie-Hellman密钥交换的攻击

## □著名的中间人攻击 (Man-in-the-Middle, MITM)

- 1)收到来自Alice的 $g^x$ 后，中间人Eva可向Bob仿冒Alice;
- 2)收到来自Bob的 $g^y$ 后，中间人Eva可向Alice仿冒Bob;
- 3)Eva可正确计算两个会话密钥 $g^{xz}$ 和  $g^{yz}$ .



# 密码协议的安全性质

## □ 协议的安全性质

- 认证性
- 机密性
- 完整性
- 不可否认性

## □ 信息系统的安全性质

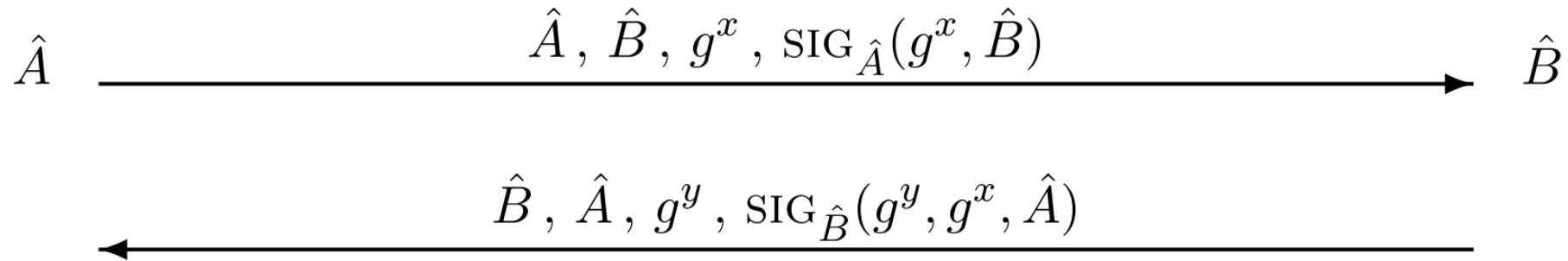
- ◆ 机密性
- ◆ 完整性
- ◆ 可用性
- ◆ 可控性
- ◆ 不可否认性

# 认证性的实现

- 目的：确保协议参与方为**意定的实体**。
- 一般通过**直接或间接共享秘密**实现：
  - 声称者使用仅为其与验证者知道的密钥封装消息，如果验证者能够成功地解密消息或验证封装是正确的，则证毕。
  - 声称者使用私钥对消息签名，验证者使用声称者的公钥验证签名，如正确，证毕。
  - 声称者通过可信第三方来证明自己。

用途： 对抗假冒攻击，确保身份的真实性，从而获取对某人或某事的信任。

## 解决方案：通过显式认证（增加双方的签名）

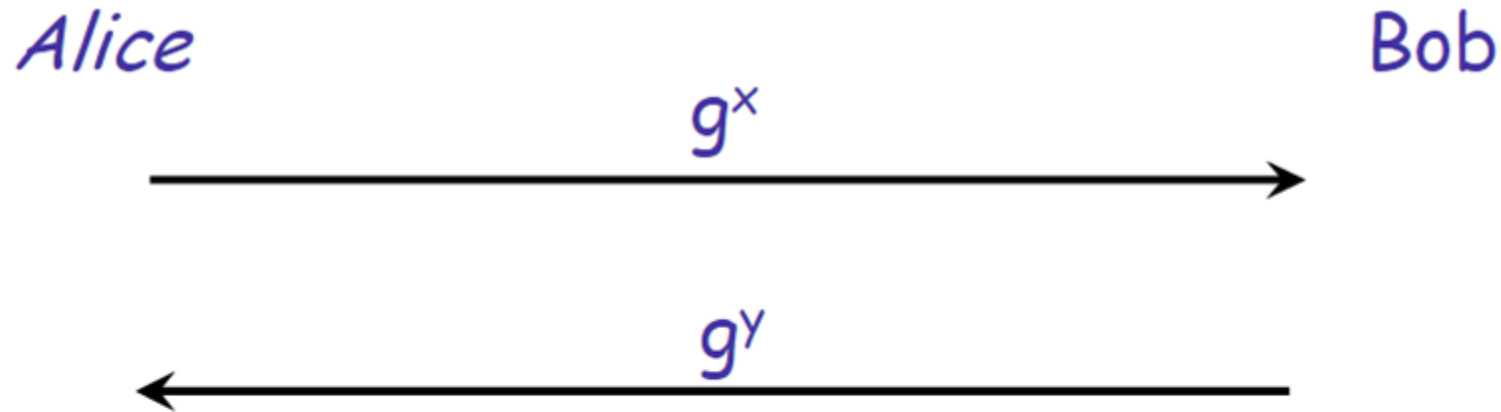


- both parties compute the secret key  $K = g^{xy} = (g^x)^y = (g^y)^x$

❑ 存在的一个明显的缺陷：一旦某一次会话的临时秘密  $x$  泄露，攻击者此后能始终仿冒  $A$ 。

❑ 这违反一个基本原则：某个会话的安全性不应影响其它会话的安全性。

## 解决方案：通过隐式认证（计算会话密钥）



- As basic DH ( $X=g^x, Y=g^y$ ), PKs:  $A=g^a, B=g^b$
- Session key  $K = ?$



# 南开大学

## 作业纸

系别

班级 密码

姓名 201601 李佳 第 页

### 1. Diffie-Hellman 协议存在中间人攻击

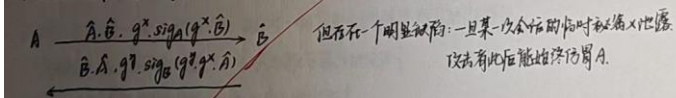
- 1) 中间人 Eva 拦截 Alice 发送的  $g^x$ , 向 Bob 伪冒 Alice 发送  $g^x$
- 2) 拦截 Bob 发送的  $g^y$ , 向 Alice 伪冒 Bob 发送的  $g^y$
- 3) Eva 分别计算  $g^{xy}$ ,  $g^{yz}$  两个会话密钥, 可以全程窃听或篡改通信, Alice 和 Bob 都无法查觉

### 2) 破坏了该协议的认证性

#### 3) 认证性一般通过直接间接共享秘密实现

- 1) 声称者使用仅为其与验证者知道的密钥封装消息, 如果验证者能够成功地解密消息或验证封装是正确的, 则证实。
- 2) 声称者使用密钥对消息签名, 验证者使用声称者的公钥验证签名, 如正确, 证实。
- 3) 声称者通过可信第三方来证明自己

#### 1) 通过显式认证 (增加双方签名)



#### 2) 通过隐式认证 (计算会话密钥)

HKDF 是迄今的 DH 和密钥交换协议

1) 相比基础 DH, 新增长期私钥  $a, b$ , 对应长期公钥  $A = g^a, B = g^b$

2) 双方最终计算的共享秘密值为  $s = g^{ax+dy+eb}$

$$\text{Alice: } s = (YB^d)^{x+da} = (g^y \cdot g^{bd})^{x+da} = g^{y(x+da)+b(x+da)}$$

$$\text{Bob: } s = (XA^d)^{y+eb} = (g^x \cdot g^{ad})^{y+eb} = g^{x(y+eb)+a(y+eb)} = g^{x(y+eb)+a(y+eb)}$$

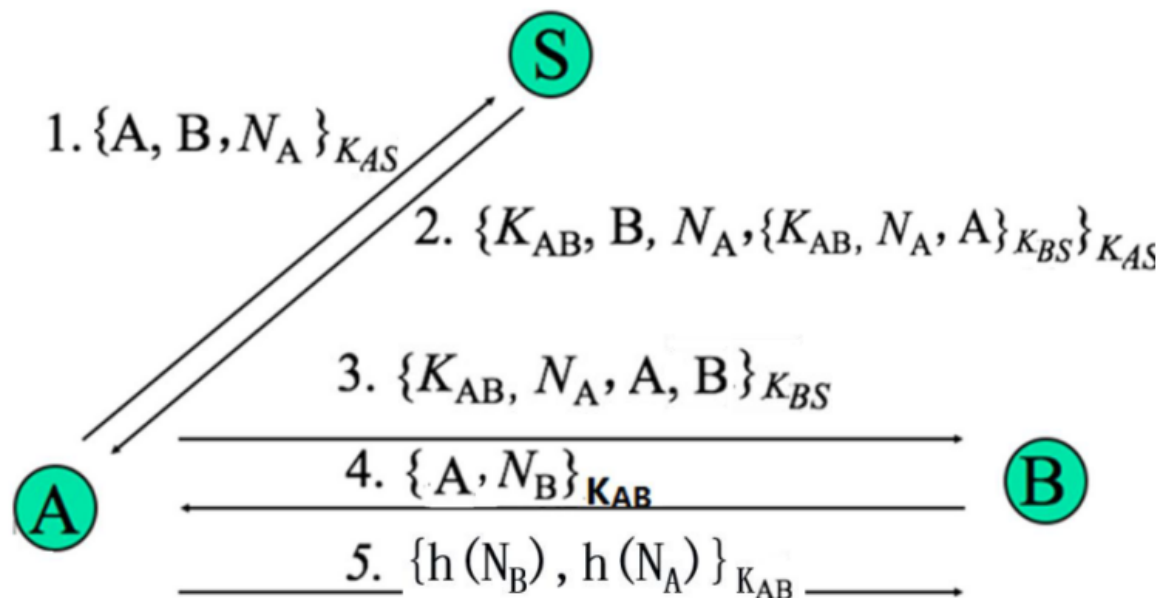
3) 哈希值  $d = H(x, "Bob")$ ,  $e = H(y, "Alice")$  既可以绑定身份与临时公钥, 又可以压缩长度。

4) 最终会话密钥  $K = H(s)$

1. Diffie-Hellman 协议存在什么协议漏洞？违反了安全协议的哪个性质，该性质一般通过什么实现？应如何改进协议。
2. HMQV 协议中使用参数  $d = H(X, \text{"Bob"})$  和  $e = H(Y, \text{"Alice"})$ ，将意定通信方的身份与密钥派生进行绑定，这样处理的目的是什么？如果改为  $d = H(X)$  和  $e = H(Y)$ ，是否存在安全缺陷？
3. Needham-Schroeder 协议使用什么机制保障消息的新鲜性？试找出 NS\_v6 协议存在的安全缺陷。

### Needham-Schroeder对称密钥认证协议\_v6

□改进策略：令消息5为  $\{h(N_B), h(N_A)\}_{K_{AB}}$



# MQV: 不安全的Diffie-Hellman密钥交换

## UKS攻击

Handwritten notes illustrating the UKS attack on MQV:

①  $A = g^a$

$\hat{A}, X = g^x \rightarrow$

$\hat{C}, Z = X A^d g^{-z}$

②  $C = g^c$

$z \in_{\mathbb{R}} \mathbb{Z}_2;$   
 $Z = X A^d g^{-z};$   
 $c = f^{-1} z \bmod q;$   
 $C = g^c;$

③  $B = g^b$

$y \in_{\mathbb{R}} \mathbb{Z}_2;$   
 $Y = g^y;$

$\hat{B}, Y = g^y \leftarrow$

$k_{CB} = (Z \cdot C^f)^{y+eb}$   
 $= (X A^d g^{-z} \cdot g^{f^{-1} z \cdot f})^{y+eb}$   
 $= (X A^d)^{y+eb}$

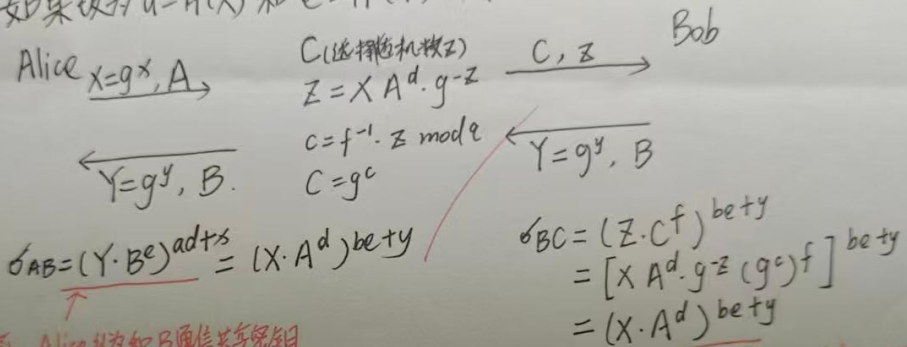
其中,  $d, e, f$  都是公开可计算的:

$d = 2^l + (x \bmod 2^l); // l = \frac{|q|}{2}$   
 $e = 2^l + (y \bmod 2^l);$   
 $f = 2^l + (z \bmod 2^l);$

$k_{AB} = (Y B^e)^{x+da}$

2. 答: 在HMQV中, 将  $d=H(X, \text{Bob})$ ,  $e=H(Y, \text{Alice})$ , 将  $f=H(Z, \text{Alice})$  与特定通信方的身份ID进行绑定, 是为了防止未知密钥共享攻击即 UKS.

如果改为  $d=H(X)$  和  $e=H(Y)$ , 则会受到 UKS 攻击, 过程如下:



Alice 计算, Alice 认为和 B 通信共享密钥

Bob 计算, 认为和 C 通信

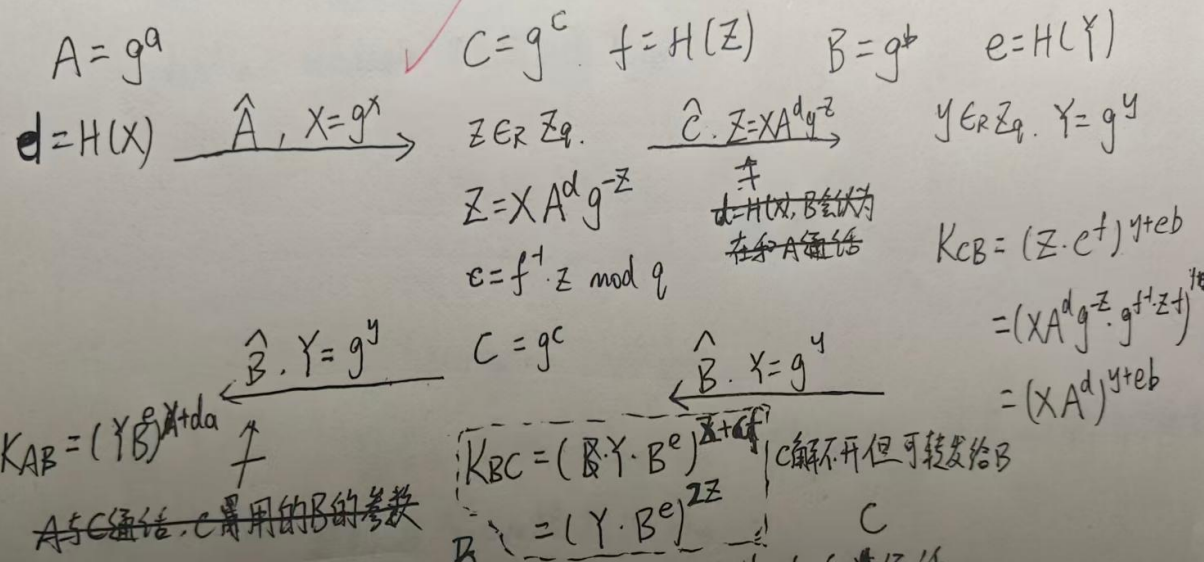
其中  $d, e, f$  均没有与身份绑定  
 $d=H(X), e=H(Y), f=H(Z)$

由于  $\sigma_{AB} = \sigma_{BC}$

密钥  $K=h(\sigma)$  相同, UKS 攻击成功

攻击成功的关键在于:  $d, e, f$  未与身份绑定, 则 Bob 和 C 通信, 和 Alice 通信, 计算的  $e=H(Y)$  是相同的,  $\sigma_{AB} = \sigma_{BC}$ .  
 如果是 HMQV, Bob 和 Alice 共享密钥:  $e=H(Y, \text{Alice})$ ,  
 Bob 和 C 共享密钥:  $e=H(Y, \text{Bob})$ ,  
 有  $\sigma_{AB} \neq \sigma_{BC}$ , 所以  $K \neq H(\sigma)$ .  
 所以, HMQV 可以抵抗上述这种攻击.

② 存在, 仍会受到 UKS 攻击, 就像 MQV 方案一样.



$K_{AB} = (Y \cdot B^e)^{ad+as}$

A 与 C 通信, C 是用的 B 的参数

$K_{BC} = (Z \cdot C^f)^{be+by}$

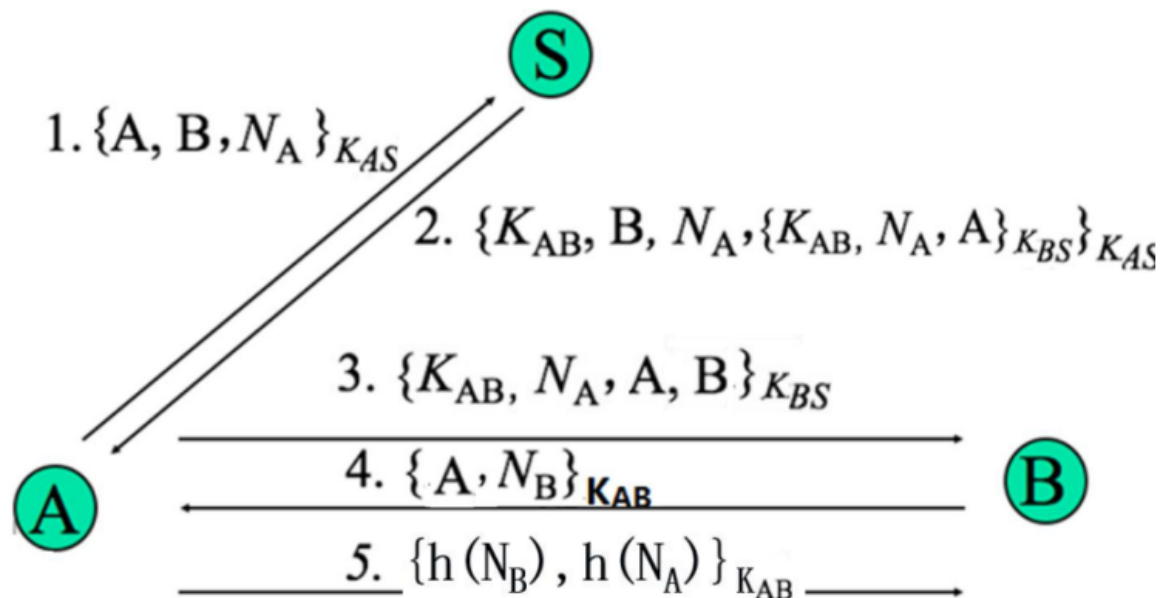
$B = (Y \cdot B^e)^{2z}$

这样 Alice 认为在和 B 通话, Bob 认为在和 C 通话.  
 $B = K_{BC}$ , 当 A 向 B 发送密文时, C 虽然解不开, 但是可以转发给 B, B 使用  $K_{BC}$  解密文, 破坏了认证性.  
 因此需要改进为 HMQV 实现显式身份确认

1. Diffie-Hellman 协议存在什么协议漏洞？违反了安全协议的哪个性质，该性质一般通过什么实现？应如何改进协议。
2. HMQV 协议中使用参数  $d = H(X, \text{"Bob"})$  和  $e = H(Y, \text{"Alice"})$ ，将意定通信方的身份与密钥派生进行绑定，这样处理的目的是什么？如果改为  $d = H(X)$  和  $e = H(Y)$ ，是否存在安全缺陷？
3. Needham-Schroeder 协议使用什么机制保障消息的新鲜性？试找出 NS\_v6 协议存在的安全缺陷。

### Needham-Schroeder对称密钥认证协议\_v6

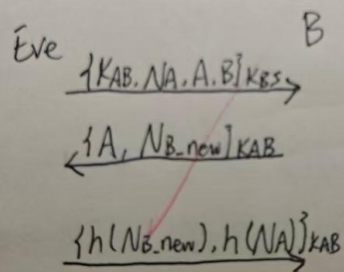
□改进策略：令消息5为  $\{h(N_B), h(N_A)\}_{K_{AB}}$



② 仍会受到重放攻击. 针对响应方B的重放攻击.

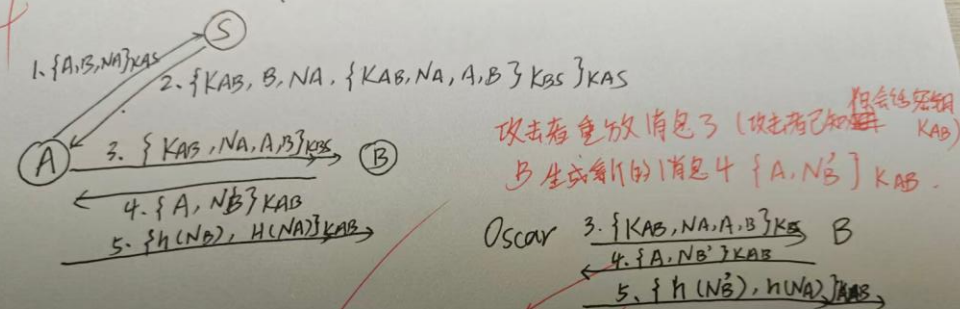
由于  $N_A$  是由A生成的. B无法判断  $N_A$  生成的时间. 则攻击者Eve就可冒充A欺骗B

假设 Eve 获得旧密钥  $K'_{AB}$ . 则其可解密该次通话记录. 得到  $h(N_B)$ .  $h(N_A)$ . 则对B发起攻击



B解密后, 发现  $N_{B.new}$  一致. 同时  $N_A$  一致. 以为在和A进行通信. 实际在与Eve进行通信。

Needham-Schroeder 协议使用: 加入挑战-响应机制来保证消息  
NS-V6 协议缺陷: 和之前的版本一样存在重放攻击 (的新版本)



攻击者重放消息3 (攻击者已知  $K_{AB}$ )  
B生成新的消息4  $\{A, N_B'\}_{K_{AB}}$

因为Oscar知道  $K_{AB}$ , 可以从消息4拿到  $N_B'$

Oscar利用旧会话里的消息5和  $K_{AB}$  可解密消息5. B验证会接受, 重放攻击成功.

```

rule Alice_receives_challenge:
  let
    nonce_received = senc(~Nb, ~Kab)
    nonce_sent = senc(<h(~Na), h(~Nb)>, ~Kab)
    // nonce_sent = senc(h(<~Na, ~Nb>), ~Kab)

  in
  [
    ExchangeInitiated($A, $B, ~Kab, ~Na),
    In(nonce_received)
  ]
  --[ AliceReceivesNonce(nonce_received, ~Nb, ~Kab) ,
    AliceSendsNonce(nonce_sent) ]->
  [
    !Session($A, $B, ~Kab),
    Out(nonce_sent)
  ]

```

```

rule Bob_receives_challenge_answer:
  let
    received_nonce = senc(<h(Na), h(~Nb)>, Kab)
    // received_nonce = senc(h(<Na, ~Nb>), Kab)

  in
  [
    SessionPending($B, $A, Kab, ~Nb, Na),
    In(received_nonce)
  ]
  --[ BobReceivesNonce(received_nonce, ~Nb, Kab),
    SecretConfirmed($A, $B, Kab) ]->
  [
    !Session($B, $A, Kab)
  ]

```

```

=====
summary of summaries:

analyzed: NS.spthy

processing time: 9.13s

types (all-traces): falsified - found trace (30 steps)
Sanity (exists-trace): verified (11 steps)
Confidentiality (all-traces): verified (35 steps)
=====

```

```

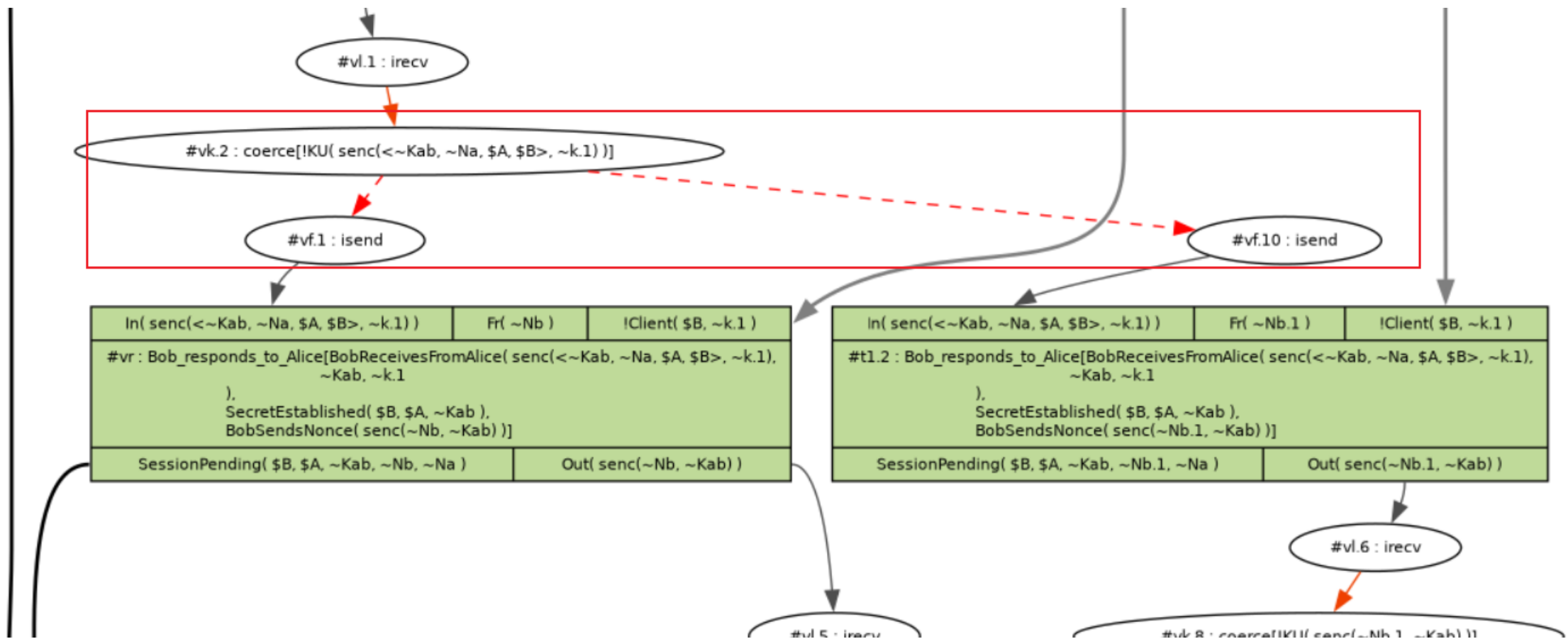
=====
summary of summaries:

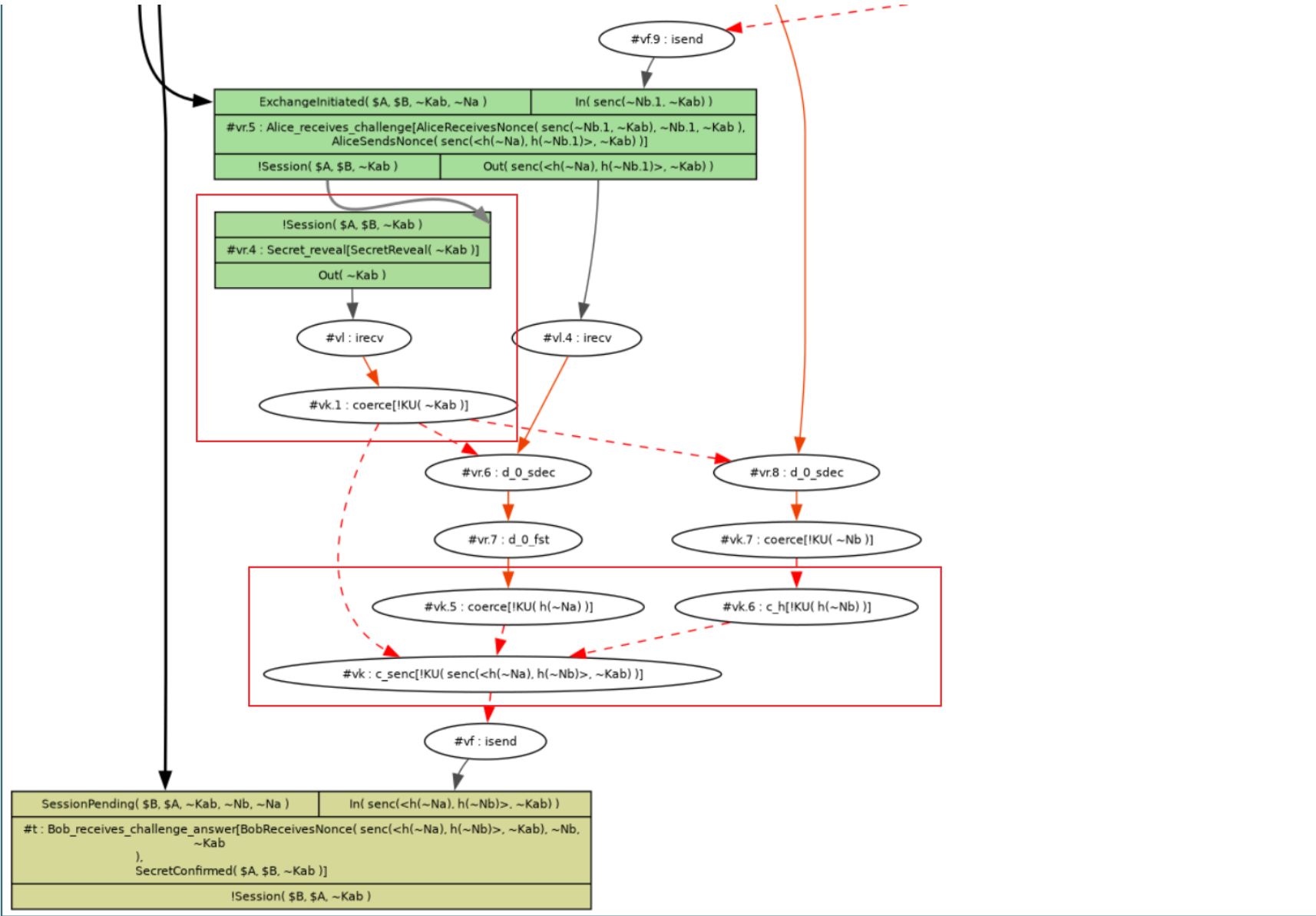
analyzed: NS.spthy

processing time: 12.37s

types (all-traces): verified (876 steps)
Sanity (exists-trace): verified (11 steps)
Confidentiality (all-traces): verified (35 steps)
=====

```





# Abadi 和 Needham 的密码协议设计原则

1. Every message should say what it means: the interpretation of the message should depend only on its content.
2. The conditions for a message to be acted upon should be clearly set out so that someone reviewing a design may see whether they are acceptable or not.
3. **If the identity of a principal is essential to the meaning of a message, it is prudent to mention the principal's name explicitly in the message.**
4. Be clear about why encryption is being done.
5. When a principal signs material that has already been encrypted, it should not be inferred that the principal knows the content of the message.
6. Be clear about what properties you are assuming about nonces.
7. If a predictable quantity is to be effective, it should be protected so that an intruder cannot simulate a challenge and later replay a response.
8. If timestamps are used as freshness guarantees, then the difference between local clocks at various machines must be much less than the allowable age of a message.
9. A key may have been used recently, for example to encrypt a nonce, and yet be old and possibly compromised.
10. It should be possible to deduce which protocol, and which run of that protocol, a message belongs to, and to know its number in the protocol.
11. The trust relations in a protocol should be explicit and there should be good reasons for the necessity of these relations.

- 每条信息都应明确其所表达的含义：对信息的解读应完全取决于其内容。
- 消息被处理的条件应明确列出，以便审查设计的人能够判断这些条件是否可接受。
- 如果主体的身份对消息的含义至关重要，那么在消息中明确提及该主体的名称是明智的。
- 要明确为什么进行加密。
- 当主体对已加密的内容进行签名时，不应推断该主体知道消息的内容。
- 要明确你对随机数（nonce）假定了什么性质。
- 如果一个可预测的量要发挥作用，它应受到保护，使得入侵者无法模拟挑战并在之后重放响应。
- 如果时间戳被用作新鲜性保证，那么各机器上本地时钟的差异必须远小于消息的允许存活时间。
- 一个密钥可能最近才被使用（例如用于加密随机数），但它可能是旧的且可能已被泄露。
- 应能推断出消息属于哪个协议以及该协议的哪次运行，并知道它在协议中的序号。
- 协议中的信任关系应是明确的，并且对这些关系的必要性应有充分的理由。

**协议设计要清晰、显式、无歧义，不要做任何隐含假设。**

Abadi, M., Needham, R.: **Prudent engineering practice for cryptographic protocols.** In: IEEE Symposium on Research in Security and Privacy, pp. 122–136. IEEE Computer Society Press (1994)